

Ethical Hacker



Networking
Academy



Programa
CiberEducação
Cisco-Brasil



Planejamento e Escopo de uma Avaliação de Teste de Penetração

Instrutor: 1º Ten Efísio





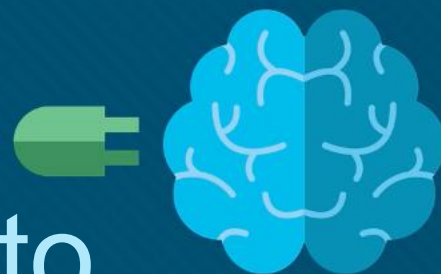
- Prof. Efísio Alves Rolim Neto:
- Instituto Militar de Engenharia 2020 - Engenharia Eletrônica
- Fundamentos de Criptografia em 2021 – Escola de Comunicações
- Estágio Setorial de *Pentest* em 2023 – Escola Nacional de Defesa Cibernética
- Metodologia de teste de invasão para Equipes de Segurança Cibernética – 41º Centro Telemática
- Guerra Cibernética para Oficiais 2024 (Pós-graduação- Lato Sensu) – Centro de Instrução de Guerra Eletrônica





Módulo 2: Planejamento e definição de escopo de uma avaliação de teste de penetração

Hacker Ético



Objetivos do Módulo

Título do módulo: Planejamento e escopo de uma avaliação de teste de penetração

Objetivo do módulo: Crie documentos preliminares de teste de penetração.

Título do tópico	Objetivo do tópico
Comparar e contrastar conceitos de governança, risco e conformidade	Explique como a governança, o risco, a conformidade e os fatores ambientais influenciam o planejamento de testes de penetração.
Explique a Importância do escopo e das necessidades organizacionais ou do cliente	Crie um escopo de teste de penetração e um documento de plano que atenda aos requisitos organizacionais para serviços de teste de penetração.
Demonstrar uma mentalidade de hacking ético mantendo profissionalismo e integridade	Crie seu código de conduta pessoal para fornecer profissionalismo e integridade em sua prática de hacking ético.

2.1 Comparando e contrastando conceitos de governança, risco e conformidade

Avatar:



Networking
Academy



Programa
CiberEducação
Cisco-Brasil



≡ 2.1.1 Visão geral



Protego Security Solutions

Parte do nosso serviço de avaliação de Security é a avaliação da adesão da Pixel Paradise a estruturas de conformidade relevantes. O não cumprimento dos requisitos de conformidade pode resultar em pesadas penalidades, e é possível que nosso cliente seja proibido de fazer negócios em determinados países por não cumprir. É muita responsabilidade!

A Pixel Paradise coleta informações de clientes como parte de seus negócios na UE e nos EUA e também lida com transações de cartão de crédito para compras feitas em sua loja virtual. Isso significa que o Pixel Paradise deve cumprir as estruturas do GDPR e do PCI DSS, entre outros.

E enquanto falamos sobre questões legais, você precisa saber sobre recursos de nossos acordos de cliente, como contratos, acordos de nível de serviço, requisitos de confidencialidade e acordos de serviço principal ou declarações de trabalho. Você precisa entender esses acordos e como eles afetam nossa prática.



Visão geral

- Uma das fases mais importantes (se não a mais importante) de qualquer teste de penetração (*pentest*) é a **fase de planejamento e preparação**.
- Durante esta fase, você delimita claramente o escopo do seu engajamento. Se você não delimitar o escopo corretamente, você terá problemas com seu cliente (se você trabalhar como um consultor) ou com seu chefe (se você fizer parte de uma equipe vermelha corporativa) e pode até enfrentar problemas legais.

OBSERVAÇÃO Uma **equipe vermelha (RED TEAM)** é um grupo de especialistas em cibersegurança e testadores de penetração contratados por uma organização para imitar um ator de ameaça real ao expor vulnerabilidades e riscos em relação à tecnologia, pessoas e segurança física. Uma **equipe azul (BLUE TEAM)** é uma equipe de segurança corporativa que defende a organização contra ameaças à segurança cibernética (isto é, os analistas da central de operações de segurança, as equipes de resposta a incidentes de segurança do computador [CSIRTs], as equipes de segurança da informação [InfoSec] e outros).

Comparando e contrastando conceitos de governança, risco e conformidade

Visão geral (Cont.)

Alguns conceitos-chave que você deve abordar e entender na fase de planejamento e preparação:

- O público-alvo
- As regras de engajamento
- O caminho de escalada de comunicações e os canais de comunicação
- Os recursos e requisitos disponíveis
- O orçamento geral para o engajamento
- Quaisquer isenções específicas
- Quaisquer restrições técnicas
- Os recursos disponíveis para você como *pentester*.

Considerações sobre conformidade regulamentar

Você deve estar familiarizado com várias considerações de conformidade regulamentar a fim de ser bem-sucedido em testes de hacking éticos e penetração – não apenas para concluir avaliações baseadas em conformidade, mas também para entender quais regulamentações podem afetar você e seu cliente.

Regulament o	Descrição
PCI DSS	A regulamentação PCI DSS (Payment Card Industry Data Security Standard, Padrão de Segurança de Dados da Indústria de Cartões de Crédito) tem como objetivo garantir o processamento de pagamentos com cartão de crédito e outros tipos de pagamentos digitais.
HIPAA	• A intenção original da Lei de Portabilidade e Prestação de Contas de Seguros de Saúde de 1996 (HIPAA) tinha como finalidade simplificar e padronizar os processos administrativos de saúde. • A simplificação administrativa exigia a transição de registros de papel e transações para registros eletrônicos e transações. • O Departamento de Saúde e Serviços Humanos dos EUA (HHS) foi instruído a desenvolver e publicar padrões para proteger as informações de saúde eletrônicas de um indivíduo, permitindo acesso e uso adequado dessas informações por provedores de saúde e outras entidades.
FedRAMP	O governo federal dos EUA usa o padrão Federal Risk and Authorization Management Program (FedRAMP) para autorizar o uso de ofertas de serviços em nuvem.

Considerações sobre conformidade regulamentar (cont.)

- A maioria dessas regulamentações e especificações exigem que a empresa regulamentada contrate empresas de teste de penetração de terceiros para garantir que elas sejam conformes e garantir que sua postura de segurança seja aceitável.
- Você deve estar familiarizado com essas regulamentações se for contratado para realizar testes de penetração para verificar a conformidade e a postura geral de segurança da organização.
- Muitos desses padrões fornecem listas de verificação dos itens que devem ser avaliados durante um teste de penetração.
- Você também deve se familiarizar com diferentes regulamentações relacionadas à privacidade, como o GDPR (General Data Protection Regulation, Regulamento Geral sobre a Proteção de Dados) em <https://gdpr-info.eu>
- Uma das principais metas do GDPR é fortalecer e unir a proteção de dados para indivíduos dentro da União Europeia (UE), ao mesmo tempo em que aborda a exportação de dados pessoais para fora da UE.

Comparando e contrastando conceitos de governança, risco e conformidade

GDPR

gdpr-info.eu/chapter-3/

 Enter number / search term → without clicking in the field

GDPR

RECITALS

KEY ISSUES

AI ACT

DATA ACT

GDPR

Chapter 1 (Art. 1 – 4)
General provisions

Chapter 2 (Art. 5 – 11)
Principles

Chapter 3 (Art. 12 – 23)
Rights of the data subject

Art. 12 – Transparent information, communication and modalities for the exercise of the rights of the data subject

Art. 13 – Information to be provided where personal data are collected from the data subject

Art. 14 – Information to be provided where personal data have not been obtained from the data subject

Art. 15 – Right of access by the data subject

Art. 16 – Right to rectification

Art. 17 – Right to erasure ('right to be forgotten')

Chapter 3

Rights of the data subject

Section 1 – Transparency and modalities

Article 12 – Transparent information, communication and modalities for the exercise of the rights of the data subject

Section 2 – Information and access to personal data

Article 13 – Information to be provided where personal data are collected from the data subject

Article 14 – Information to be provided where personal data have not been obtained from the data subject

Article 15 – Right of access by the data subject

Section 3 – Rectification and erasure

Article 16 – Right to rectification



servados.Confiden cial C is co

11

Considerações sobre conformidade regulamentar (cont.)

Regulamentações do setor financeiro

- As instituições de serviços financeiros, como bancos, cooperativas de crédito e instituições de empréstimos, fornecem uma série de soluções e instrumentos financeiros. As informações dos clientes e transacionais são o centro dos negócios.
- A proteção das informações do cliente é necessária para estabelecer e manter a confiança entre uma instituição financeira e a comunidade a qual atende.
- Mais especificamente, as instituições têm a responsabilidade de salvaguardar a privacidade dos consumidores individuais e protegê-los de danos, incluindo fraudes e roubo de identidade.
- Em uma escala mais ampla, a indústria é responsável pela manutenção da infraestrutura crítica dos serviços financeiros do país.

Comparando e contrastando conceitos de governança, risco e conformidade

Considerações sobre conformidade regulamentar (cont.)

Exemplos de regulamentações aplicáveis ao setor financeiro

- Título V, Seção 501(b) da Lei Gramm-Leach-Bliley (GLBA) e as diretrizes interagências correspondentes
- O Conselho Federal de Exame das Instituições Financeiras (FFIEC)
- A Lei de Salvaguardas da Corporação Federal de Seguro de Depósitos (FDIC) e Cartas de Instituições Financeiras (FILs)
- Regulamentação de Segurança Cibernética do Departamento de Serviços Financeiros de Nova York (NY DFS Cybersecurity Regulation; 23 NYCRR Parte 500)

O cumprimento de algumas regulamentações, como NYCRR e GLBA, é obrigatório.

Comparando e contrastando conceitos de governança, risco e conformidade

Considerações sobre conformidade regulamentar (cont.)

- A GLBA define uma instituição financeira como "qualquer instituição cujo negócio esteja significativamente envolvido em atividades financeiras, conforme descrito na Seção 4(k) da Lei da Holding Bancária (12 U.S.C. § 1843(k))". O GLBA se aplica a todas as organizações de serviços financeiros, independentemente do tamanho.
- Essa definição é importante para compreender, pois essas instituições financeiras incluem muitas empresas que não são tradicionalmente consideradas instituições financeiras, incluindo:
 - Empresas de desconto de cheques
 - Credores de empréstimos consignados
 - Corretores de hipotecas
 - Credores não bancários (por exemplo, revendedores de automóveis que fornecem serviços financeiros)
 - Fornecedores de tecnologia que fornecem empréstimos a clientes
 - Instituições educativas que oferecem ajuda financeira
 - Cobradores de dívidas
 - Provedores de serviços de liquidação imobiliária
 - Avaliadores de imóveis ou bens pessoais
 - Varejistas que emitem cartões de crédito da marca
 - Preparadores profissionais de impostos
 - Serviços de correio
- **A lei também se aplica às empresas que recebem informações sobre clientes de outras instituições financeiras, incluindo agências de relatórios de crédito.**

Considerações sobre conformidade regulamentar (cont.)

- A Comissão Federal de Comércio (FTC) é responsável por aplicar a GLBA no que diz respeito a empresas financeiras que não são cobertas por agências bancárias federais. **A GLBA exige que as organizações financeiras passem por testes de penetração periódicos em sua infraestrutura.**
- Outro exemplo é o Regulamento de Cibersegurança do NY DFS. A seção 500.05 deste regulamento exige que a entidade coberta realize testes de penetração de segurança e avaliações de vulnerabilidade continuamente. **A organização deve realizar um teste anual de penetração na segurança e uma avaliação bianual de vulnerabilidade.**

Comparando e contrastando conceitos de governança, risco e conformidade

Considerações sobre conformidade regulamentar (cont.)

Regulamentações do setor de saúde

- Em 20 de fevereiro de 2003, as Normas de Security para Proteção de Informações Eletrônicas sobre Saúde Protegida, conhecidas como **Regra de Segurança da HIPAA**, foram publicadas. A Regra de Security exige salvaguardas técnicas e não técnicas para proteger informações de saúde eletrônicas. A Regra Final de Execução de Security correspondente da HIPAA foi emitida em 16 de fevereiro de 2006. Desde então, a seguinte legislação modificou e expandiu o escopo e os requisitos da Regra de Security:
 - A Lei de Tecnologia da Informação de Saúde de 2009 para Saúde Econômica e Clínica (conhecida como Lei HITECH)
 - A regra de notificação de violação de 2009
 - As Modificações de 2013 nas Regras de Privacidade, Security, Execução e Notificação de Violação da HIPAA sob a Lei de HITECH e da Lei de Nondiscriminação de Informações Genéticas; Outras Modificações nas Regras da HIPAA (conhecida como regra Omnibus)

Comparando e contrastando conceitos de governança, risco e conformidade

Considerações sobre conformidade regulamentar (cont.)

- A HHS publicou orientações adicionais de cibersegurança para ajudar os profissionais de saúde a

Clearinghouse de Saúde	Uma entidade que processa informações de saúde não padronizadas que recebe de outra entidade em um formato padrão.
-------------------------------	--

- A Regra de Security HIPAA se concentra em salvaguardar as informações de saúde protegidas eletronicamente (ePHI), que é definida como informação de saúde individualmente identificável (IIHI) que é armazenada, processada ou transmitida eletronicamente.
- A Regra de Security HIPAA se aplica às entidades cobertas e aos associados comerciais.
- As entidades cobertas incluem prestadores de cuidados de saúde, planos de saúde, clearinghouses de saúde e certos associados comerciais.

Comparando e contrastando conceitos de governança, risco e conformidade

Considerações sobre conformidade regulamentar (cont.)

Padrão de Segurança de Dados da Indústria de Cartões de Crédito (PCI DSS)

- Para proteger os titulares de cartão contra o mau uso de suas informações pessoais e minimizar as perdas de canais de cartão de pagamento, as principais marcas de cartões de pagamentos (Visa, MasterCard, Discover e American Express) formaram o Payment Card Industry Security Standards Council (PCI SSC) e desenvolveram o Padrão de Security de Dados da Indústria de Cartões de Crédito (PCI DSS).
- O PCI DSS deve ser adotado por qualquer organização que transmita, processe ou armazenem dados de cartão de pagamento ou que afete direta ou indiretamente a segurança dos dados do titular do cartão. Qualquer organização que utilize um terceiro para gerenciar dados de titulares de cartão tem a responsabilidade total de garantir que esse terceiro seja compatível com o PCI DSS. As marcas de cartões de pagamento podem cobrar multas e penalidades contra organizações que não cumprem os requisitos e/ou podem cancelar sua autorização para aceitar cartões de pagamento.

Considerações sobre conformidade regulamentar (cont.)

- Para combater o potencial de perdas surpreendentes, as marcas de cartões de pagamento exigem contratualmente que todas as organizações que armazenam, processam ou transmitem dados do titular de cartão e/ou dados de autenticação confidenciais sejam compatíveis com o PCI DSS. Os requisitos de PCI DSS se aplicam a todos os componentes do sistema onde os dados da conta são armazenados, processados ou transmitidos.

Considerações sobre conformidade regulamentar (cont.)

Elementos técnicos principais das regulamentações que você deve considerar

A maioria dos regulamentos dita vários elementos-chave, e um *pentester* deve prestar atenção e verificá-los durante a avaliação para garantir que a organização seja compatível.

Isolamento de dados	Também conhecido como isolamento de rede ou segmentação de rede, o objetivo é implementar uma rede completamente isolada que inclua todos os sistemas envolvidos no processamento de cartões de pagamento.
Gerenciamento de senhas	A maioria dos regulamentos determina estratégias sólidas de gerenciamento de senhas. Por exemplo, as organizações não devem usar padrões fornecidos pelo provedor para senhas de sistema e parâmetros de segurança. A maioria dessas regulamentações determina padrões de implementação específicos, incluindo duração da senha, complexidade da senha e tempo limite da sessão, bem como o uso da autenticação multifator.
Gerenciamento de Chaves	<i>Chave</i> é um valor que especifica qual parte do algoritmo aplicar e em que ordem, bem como quais variáveis inserir. É fundamental usar uma chave forte que não pode ser descoberta e proteger a chave do acesso não autorizado.

Restrições locais

- Você deve estar ciente de quaisquer restrições locais quando você é contratado para realizar testes de penetração.
- Por exemplo, você pode estar viajando para o exterior para um país diferente onde pode haver limitações específicas do país e leis locais que podem restringir se você pode executar algumas tarefas como um pentester.
- **As leis de teste de penetração variam de país para país.**
- Você deve sempre ter a documentação clara do seu cliente (a entidade que o contratou) indicando que você tem permissão para realizar o teste.
- Claramente, algumas dessas limitações e considerações podem ter um impacto direto no seu contrato e declaração de trabalho (SOW – *Statement of Work*).

Restrições locais (cont.)

- Durante as tarefas pré-compromisso, você deve identificar as restrições de teste, incluindo restrições de ferramenta.
- Muitas vezes, você será limitado por alguns aspectos do negócio e da tecnologia na organização que o contratou (mesmo delineando as ferramentas que você pode usar ou não está autorizado a usar durante o compromisso de teste de penetração).

Alguns exemplos de restrições que você pode enfrentar durante um teste de penetração:

- Algumas áreas e tecnologias que não podem ser testadas devido a limitações operacionais (Por exemplo, você talvez não seja capaz de iniciar **ataques de injeção de SQL específicos**, pois isso poderia corromper um banco de dados de produção.)
- Tecnologias que podem ser específicas para a organização que está sendo testada
- Limitação de explorações conhecidas
- Sistemas categorizados como fora de escopo devido à criticidade ou problemas de desempenho conhecidos

Restrições locais (Cont.)

- **Você deve comunicar claramente quaisquer restrições técnicas com as partes interessadas apropriadas da organização que o contratou antes e durante o teste.**

Comparando e contrastando conceitos de governança, risco e conformidade

Conceitos Legais

Existem vários conceitos legais importantes que você deve saber ao realizar um teste de penetração:

Contrato de nível de serviço (SLA - Service Level Agreement)	Uma expectativa ou restrição bem documentada relacionada a uma ou mais das medidas mínimas e/ou máximas de desempenho (como qualidade, prazo/cronograma e custo) do serviço de teste de penetração.
Confidencialidade	Você deve discutir e concordar com o tratamento de dados confidenciais. Por exemplo, se você pode encontrar senhas ou outros dados confidenciais, você precisa revelar todas essas senhas ou todos esses dados confidenciais? Quem terá acesso a dados confidenciais? Qual será a maneira adequada de se comunicar e lidar com esses dados? Da mesma forma, você deve proteger dados confidenciais e excluir todos os registros, de acordo com seu contrato com seu cliente. Toda vez que você termina um teste de penetração, você deve excluir qualquer registro de seus sistemas.

Conceitos Legais (Cont.)

Existem vários conceitos legais importantes que você deve saber ao realizar um teste de penetração:

Declaração de trabalho (SOW - *Statement of Work*)

Um documento que especifica as atividades a serem realizadas durante um teste de penetração. Ela pode ser usada para definir alguns dos seguintes elementos:

- Cronogramas do projeto (testes de penetração), incluindo o cronograma de entrega de relatório
- O escopo do trabalho a ser executado
- O local do trabalho (localização geográfica ou localização de rede)
- Requisitos técnicos e não técnicos especiais
- Cronograma de pagamento
- Itens diversos que podem não fazer parte da negociação principal, mas que precisam ser listados e rastreados, pois podem apresentar problemas durante o projeto geral

Comparar e contrastar conceitos de governança, risco e conformidade

Conceitos legais (Cont.)

Existem vários conceitos legais importantes que você deve saber ao realizar um teste de penetração:

Acordo de nível de serviço (MSA - <i>Master Service Agreement</i>)	MSAs são contratos que podem ser usados para negociar rapidamente o trabalho a ser realizado. Quando um acordo mestre está em vigor, os mesmos termos não precisam ser renegociados toda vez que você executa o trabalho para um cliente. MSAs são especialmente benéficas quando você executa um <i>pentest</i> , e sabe que será recontratado de forma recorrente para realizar testes adicionais em outras áreas da empresa ou para verificar se a postura de segurança da organização foi melhorada como resultado de testes anteriores e remediação.
---	---

Conceitos Legais (Cont.)

Existem vários conceitos legais importantes que você deve saber ao realizar um teste de penetração:

Acordo de não divulgação (NDA - *Non-Disclosure Agreement*)

Um documento legal e contrato entre você e uma organização que o contratou como testador de penetração. Um NDA especifica e define material confidencial, conhecimento e informações que não devem ser divulgadas e que devem ser mantidas confidenciais por ambas as partes. Os acordos de confidencialidade podem ser classificados como qualquer um dos seguintes:

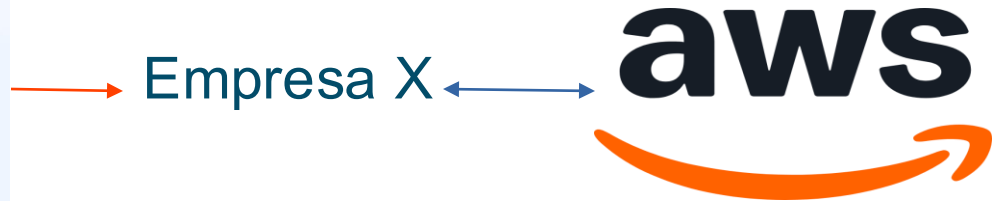
- **Unilateral:** Com um acordo de confidencialidade unilateral, apenas uma parte revela certas informações à outra parte, e as informações devem ser mantidas protegidas e não divulgadas. Por exemplo, uma organização que contrata você deve incluir em um acordo de confidencialidade certas informações que você não deve revelar.
- **Bilateral:** Também é referido como um acordo de confidencialidade mútuo, ou bidirecional. Em um acordo de confidencialidade bilateral, ambas as partes compartilham informações confidenciais entre si, e essas informações não devem ser divulgadas a nenhuma outra entidade.
- **Multilateral:** Envolve três ou mais partes, com pelo menos uma das partes divulgando informações confidenciais que não devem ser divulgadas a nenhuma entidade fora do acordo. NDAs Multilaterais são usados no caso de uma organização externa ao seu cliente (parceiro de negócios, provedor de serviços e assim por diante) também deve estar engajada no compromisso de teste de penetração.

Contratos

- O contrato é um dos documentos mais importantes em um teste de penetração. Especifica os termos do contrato e como você será pago, e fornece documentação clara dos serviços que serão realizados.
- Um contrato deve ser muito específico, fácil de entender e sem ambiguidades. Qualquer ambiguidades provavelmente levará a insatisfação e atrito dos clientes.
- O aconselhamento jurídico (de um advogado) é sempre recomendado para qualquer contrato.
- Um cliente pode especificar e exigir que qualquer informação coletada ou analisada durante o teste de penetração não possa ser disponibilizada fora do país onde você realizou o teste.
- Além disso, o cliente pode especificar que você (como testador de penetração) não pode remover informações de identificação pessoal (PII) que possam estar sujeitas a leis ou regulamentações específicas sem antes se comprometer a ser vinculado a essas leis e regulamentações ou sem a autorização por escrito da empresa.
- Seu cliente também revisará o contrato ou acordo de teste de penetração para garantir que ele não permita mais risco do que se destina a resolver.

Contratos (cont.)

- Outro elemento muito importante do seu contrato e das tarefas de pré-compromisso é que você deve obter uma assinatura de uma autoridade competente para assinar o seu contrato.
- Isso inclui autorização por escrito para que o trabalho seja executado.
- Se necessário, você também deverá ter autorização por escrito de qualquer provedor de terceiros ou parceiro de negócios.
- Isso incluiria, por exemplo, provedores de serviços de Internet, provedores de serviços em nuvem ou qualquer outra entidade externa que pudesse ser afetada ou relacionada ao teste de penetração a ser realizado.
- Exemplo:



Isenções

- Talvez você queira adicionar isenções à documentação de pré-avaliação, bem como no relatório final.
- Por exemplo, você pode especificar que conduziu testes de penetração nos aplicativos e sistemas que existiam a partir de uma data claramente declarada. **As ameaças à segurança cibernética estão sempre mudando, e novas vulnerabilidades são descobertas diariamente. Nenhum software, hardware ou tecnologia é imune a vulnerabilidades de segurança, não importa quanto teste de segurança seja conduzido.**

Isenções

- Talvez você queira adicionar isenções à documentação de pré-avaliação, bem como no relatório final.
- Por exemplo, você pode especificar que conduziu testes de penetração nos aplicativos e sistemas que existiam a partir de uma data claramente declarada. **As ameaças à segurança cibernética estão sempre mudando, e novas vulnerabilidades são descobertas diariamente. Nenhum software, hardware ou tecnologia é imune a vulnerabilidades de segurança, não importa quanto teste de segurança seja conduzido.**
- [Exploit-db.com](https://www.exploit-db.com)



Comparar e contrastar conceitos de governança, risco e conformidade

Isenções

- Explot-db.com

Date	D	A	V	Title	Type	Platform	Author
2026-04-29	↓	×		LangChain Core 1.2.4 - SSTI/RCE	WebApps	Multiple	banyamer
2026-04-29	↓	×		AtlonA ATOMERX21 - Authenticated Command Injection	Local	Multiple	rizzziom
2026-04-22	↓	×		Throttlestop Kernel Driver - Kernel Out-of-Bounds Write Privilege Escalation	Local	Windows	Xavi Beltran
2026-04-22	↓	×		WordPress Plugin 5.2.0 - Broken Access Control	WebApps	Multiple	cydev.turing
2026-04-22	↓	×		AVAST Antivirus 25.11 - Unquoted Service Path	Local	Windows	Milad Karimi (Ex3ptionaL)

Date	D	A	V	Title	Type	Platform	Author
2026-04-30	↓	×		FUXA 1.2.8 - Authentication Bypass + RCE Exploit	WebApps	Multiple	joshua
2026-04-30	↓	×		Python-Multipart 0.0.22 - Path Traversal	WebApps	Python	jefersoncardoso.dev
2026-04-30	↓	×		Google Chrome 145.0.7632.75 - CSSFontFeatureValuesMap	Local	Multiple	nu11secu1ty
2026-04-30	↓	×		Windows 11 23H2 - Denial of Service (DoS)	Local	Windows	tryhardertryh
2026-04-30	↓	×		Repetier-Server 1.4.10 - Path Traversal	WebApps	Multiple	banyamer
2026-04-30	↓	×		HUSTOJ Zip-Slip v26.01.24 - RCE	WebApps	Multiple	Marshall Whittaker

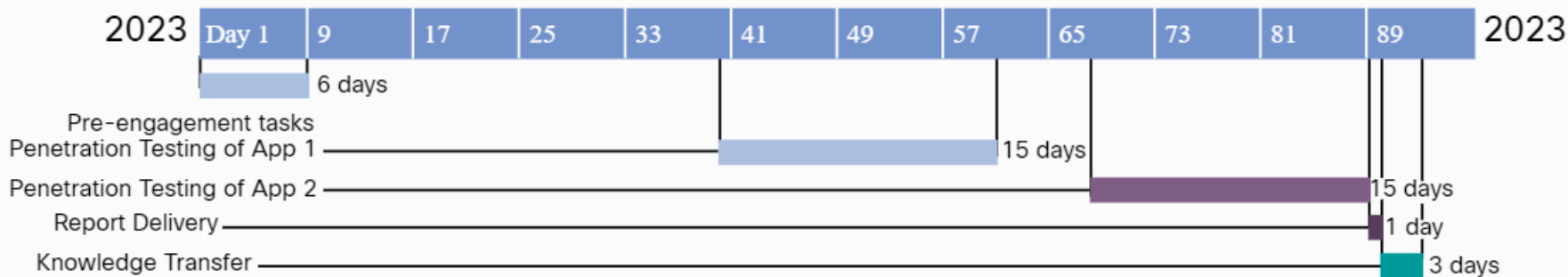
Comparar e contrastar conceitos de governança, risco e conformidade

Isenções

- [Exploit-db.com](https://exploit-db.com)

Date	D	A	V	Title	Type	Platform	Author
2026-04-30	↓	×		FUXA 1.2.8 - Authentication Bypass + RCE Exploit	WebApps	Multiple	joshua
2026-04-30	↓	×		LangChain Core 1.2.4 - SSTI/RCE	WebApps	Multiple	banyamer

SecretCorp Penetration Testing Project Plan



Isenções

- Talvez você queira adicionar isenções à documentação de pré-avaliação, bem como no relatório final.
- Por exemplo, você pode especificar que conduziu testes de penetração nos aplicativos e sistemas que existiam a partir de uma data claramente declarada. **As ameaças à segurança cibernética estão sempre mudando, e novas vulnerabilidades são descobertas diariamente. Nenhum software, hardware ou tecnologia é imune a vulnerabilidades de segurança, não importa quanto teste de segurança seja conduzido.**
- Você também deve especificar que o relatório de teste de penetração se destina apenas a fornecer documentação e que seu cliente determinará a melhor maneira de remediar quaisquer vulnerabilidades. Além disso, você deve incluir um aviso de que o seu relatório de teste de penetração não pode e não protege contra perda pessoal ou comercial como resultado do uso dos aplicativos ou sistemas descritos nele.
- Outra isenção padrão é que você (ou suas organizações) não fornece garantias, declarações ou certificações legais relativas a aplicativos ou sistemas que foram ou serão testados. Um aviso pode dizer que seu relatório de testes de penetração não representa ou garante que o aplicativo testado seja adequado para a tarefa e livre de outras vulnerabilidades ou defeitos funcionais além dos relatados. Além disso, é padrão incluir uma isenção indicando que tais sistemas não estão em total conformidade com qualquer padrão da indústria ou não são totalmente compatíveis com qualquer sistema operacional, hardware ou outro aplicativo.

2.1.9 Laboratório - Requisitos de conformidade e restrições locais

Neste laboratório, você irá cumprir os seguintes objetivos:

- Pesquise serviços de teste de penetração fornecidos por consultores de segurança para estruturas de conformidade.
- Realize uma pesquisa das empresas de teste de penetração.

2.2 Explicando a importância do escopo e das necessidades organizacionais e do cliente

Regras de Engajamento

- O **documento** de **regras de engajamento** especifica as condições sob as quais o teste de penetração de segurança será conduzido. É necessário documentar e concordar com estas condições das regras de engajamento com o cliente ou com uma parte interessada apropriada.

Tabela 2-3 Elementos Exemplares de um documento de regras de engajamento

Elemento das Regras de Engajamento	Exemplo
Cronograma de Testes	Três semanas.Conforme especificado em um gráfico Gantt
Local do teste	Sede da empresa em Raleigh, Carolina do Norte
Janela de tempo do teste (hora do dia)	Das 9h às 17h. EST
Método de comunicação preferencial	Relatório final e reuniões de atualização do status semanal

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

Regras de Engajamento (Cont.)

Tabela 2-3 Elementos de amostra de um documento de regras de engajamento (continuação)

Elemento de Regra de Engajamento	Exemplo
Os controles de segurança que podem potencialmente detectar ou prevenir testes	Sistemas de prevenção de intrusão (IPSs), firewalls, sistemas de prevenção de perda de dados (DLP)
Endereços IP ou redes a partir dos quais o teste será originado	10.10.1.0/24, 192.168.66.66, 10.20.15.123
Tipos de testes permitidos ou não permitidos	Testando apenas aplicativos da Web (app1.secretcorp.org e app2.secretcorp.org). Não são permitidos ataques de engenharia social. Nenhum ataque de injeção de SQL é permitido no ambiente de produção. A injeção de SQL é permitida apenas nos ambientes de desenvolvimento e preparação em: app1-dev.secretcorp.org app1-stage.secretcorp.org app2-dev.secretcorp.org app2-stage.secretcorp.org



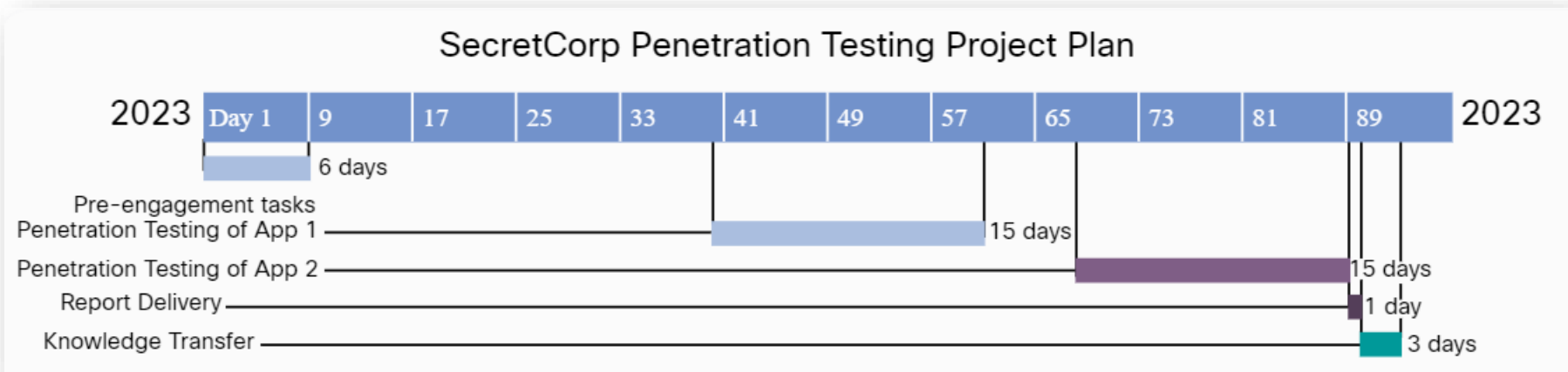
Programa
CiberEducação
Cisco-Brasil



Regras de Engajamento (Cont.)

Gráficos gantt e estruturas de decomposição do trabalho (WBS) podem ser usados como ferramentas para demonstrar e documentar a linha do tempo.

Figura 2-1 Exemplo de Gráfico de Gantt



2.2.3 Prática - Regras de Engajamento

2.2.3 Prática - Regras de engajamento

A Protego acaba de assinar um novo cliente e você precisa rever as regras de envolvimento antes de começar o projeto. Quais são os três componentes do acordo que são relevantes para as regras de envolvimento? (Escolha três.)

Acesso ao código-fonte

Os nomes e credenciais do pessoal que está executando o teste

Custo do serviço e cronograma de pagamento

Lista de destinos e ativos em escopo

- O escopo é um dos elementos mais importantes das tarefas pré-engajamento com qualquer engajamento de teste de penetração.
- Não só é preciso identificar e documentar cuidadosamente todos os sistemas, aplicativos e redes que serão testados, mas também determinar quaisquer requisitos e qualificações específicos necessários para realizar o teste.
- Quanto mais amplo o escopo do teste de penetração, mais habilidades e requisitos serão necessários.
- Seu escopo e documentação relacionada devem incluir informações sobre quais tipos de redes serão testados.
- Além dos intervalos de IP, você deve documentar todas as redes sem fio ou identificadores do conjunto de serviços (SSIDs) que você tem permissão ou não está autorizado a testar.
- Você também pode ser contratado para realizar uma avaliação de aplicativos modernos usando diferentes interfaces de programação de aplicativos (APIs).

Lista de destinos e ativos em escopo (Cont.)

Tipos de documentação da API:

Protocolo de Acesso a Objetos Simples (SOAP)	SOAP é um padrão de API que conta com XML e esquemas relacionados.As especificações baseadas em XML são regidas por documentos XML Schema Definition (XSD).Ter uma boa referência do que uma API específica suporta pode ser muito benéfica para um testador de penetração e acelerará os testes.
Swagger	A documentação de Swagger (OpenAPI) é uma estrutura moderna da documentação e desenvolvimento da API que hoje é a base da Especificação da OpenAPI (OAS).Esses documentos são usados em APIs de transferência de estado representativas (REST).REST é um estilo de arquitetura de software projetado para orientar o desenvolvimento da arquitetura para serviços Web (incluindo APIs).REST ou "RESTful" APIs são os tipos mais comuns de APIs usados hoje em dia.Documentos Swagger podem ser extremamente benéficos ao testar APIs.
WSDL	WSDL (Web Services Description Language, Linguagem de Descrição de Serviços Web) é uma linguagem baseada em XML usada para documentar a funcionalidade de um serviço da Web.

Lista de destinos e ativos em escopo (Cont.)

Tipos da documentação da API (Continuação):

GraphQL	O GraphQL é uma linguagem de consulta para APIs. É também um tempo de execução do lado do servidor para executar consultas usando um sistema do tipo que você define para seus dados.
WADL	Web Application Description Language (Linguagem de descrição de aplicativos da Web, WADL) é uma linguagem baseada em XML que descreve os aplicativos da Web.
WSDL	WSDL (Web Services Description Language, Linguagem de Descrição de Serviços Web) é uma linguagem baseada em XML usada para documentar a funcionalidade de um serviço da Web.

Lista de destinos e ativos em escopo (Cont.)

Recursos de suporte adicionais que você poderia obter da organização que o contratou para realizar o teste de penetração:

Kit de desenvolvimento de software (SDK) para aplicativos específicos	Um SDK ou devkit é um conjunto de ferramentas de desenvolvimento de software que pode ser usadas para interagir e implementar uma estrutura de software, um sistema operacional ou uma plataforma de hardware. Os SDKs também podem ajudar os testadores de penetração a entender determinados aplicativos e plataformas de hardware especializados dentro da organização que está sendo testada.
Acesso ao Código-fonte	Algumas organizações podem permitir que você obtenha acesso ao código-fonte de aplicativos a serem testados.
Exemplos de solicitações de aplicativo	Na maioria dos casos, você poderá revelar o contexto usando ferramentas de teste de aplicativos Web, como proxies como o Burp Suite e o OWASP Zed Attack Proxy (ZAP).
Diagramas de arquitetura de sistema e rede	Esses documentos podem ser muito benéficos para testadores de penetração, e podem ser usados para documentar e definir quais sistemas estão em escopo durante os testes.

Lista de destinos e ativos em escopo (Cont.)

- ***Crescimento do escopo*** é um termo de gerenciamento de projetos que se refere ao crescimento descontrolado do escopo de um projeto. Também é frequentemente referido como *síndrome da pia da cozinha*, *crescimento de requisitos*, e *crescimento de função*. O aumento do escopo pode fazer você sair do negócio.
- Muitas empresas de segurança sofrem com o aumento do escopo e falham porque não têm ideia de como identificar quando o problema começa ou como reagir a ele.

Lista de destinos e ativos em escopo (Cont.)

Situações em que um aumento de escopo pode ocorrer:

Gerenciamento de Mudanças	Quando há uma má gestão de mudanças no engajamento de teste de penetração.
Elementos técnicos e não técnicos	Quando há uma identificação ineficaz de quais elementos técnicos e não técnicos serão necessários para o teste de penetração.
Má comunicação	Quando há má comunicação entre as partes interessadas, incluindo seu cliente e sua própria equipe.

- **O aumento do escopo nem sempre é uma situação ruim.** Por exemplo, um cliente satisfeito com o trabalho que você está fazendo no seu projeto pode solicitar que você execute testes adicionais ou trabalho técnico.
- Alterações no gerenciamento e a comunicação clara são cruciais para evitar uma situação muito desconfortável e ruim.
- Se você inicialmente entrou em contato com seu cliente após uma solicitação de proposta (RFP), e é necessário um trabalho adicional que não fazia parte do RFP ou da sua declaração de trabalho inicial, você deve pedir que uma nova declaração de trabalho seja assinada e acordada.

2.2.5 Prática - Lista de destinos e Ativos em escopo

2.2.5 Prática - Lista de destinos e ativos no escopo

Você está estudando o acordo de teste de penetração para um novo compromisso com um dos clientes da Protego. Você está especialmente interessado nas informações que o cliente fornecerá à Protego para suportar o teste. Quais ativos técnicos podem ser identificados conforme fornecido no escopo do teste? (Escolha três.)

- ☐ Acordos de não divulgação
- ☐ Documentos de arquitetura do sistema e de topologia de rede
- ☐ Credenciais e habilidades da equipe de teste de penetração
- ☐ O acordo de nível de serviço
- ☐ Documentação da API

Validando o escopo de engajamento

- A primeira etapa na validação do escopo de um compromisso é questionar o cliente e revisar os contratos.
- Você também deve entender quem é o público-alvo para seu relatório de testes de penetração.
- Você deve entender os assuntos, unidades comerciais e qualquer outra entidade que será avaliada por tal avaliação de testes de penetração.

Perguntas a serem feitas para descobrir diferentes características do público-alvo:

Primeira pergunta	Qual é a necessidade da entidade ou do indivíduo pelo relatório?
Destinatário principal do relatório	Qual é a posição do indivíduo que será o destinatário principal do relatório na organização?
Propósito e objetivo	Qual é o propósito e objetivo principal do engajamento de teste de penetração e, em última análise, do objetivo do relatório?
Responsabilidade e autoridade	Qual é a responsabilidade e autoridade do indivíduo ou da unidade comercial para tomar decisões com base em suas conclusões?
Relatar endereço para	A quem o relatório será endereçado— por exemplo, o gerente de segurança da informação (ISM), o diretor de segurança da informação (CISO), o diretor de informática (CIO), o diretor técnico (CTO), as equipes técnicas e assim por diante?
Outros com acesso ao relatório	Quem terá acesso ao relatório, que pode conter informações confidenciais que devem ser protegidas, e se o acesso será fornecido com base na necessidade de saber?

Validação do escopo de compromisso (cont.)

Você deve sempre ter boas linhas abertas de comunicação com os clientes e com as partes interessadas que o contratam

Você deve ter a documentação adequada das respostas para as perguntas a seguir.

Partes interessadas relevantes	Quais são as informações de contato para todas as partes interessadas relevantes?
Processo de comunicação	Como você se comunicará com as partes interessadas?
Cronograma das interações	Com que frequência você precisa interagir com as partes interessadas?
Contatos de emergência	Quem são os indivíduos que você pode contatar a qualquer momento se surgir uma emergência?

Validação do escopo de engajamento (cont.)

Figura 2-2 - Exemplo de cartão de partes interessadas e contato de emergência

PRIMARY STAKEHOLDER			
Name		Email	
Title		Responsibility	
Work Number	Mobile Phone	Other Number	Alternate Email
Address		Notes	
City		State	ZIP Code
EMERGENCY CONTACTS			
Primary Emergency Contact		Secondary Emergency Contact	
Phone	Email	Phone	Email
Address		Address	
City, ST ZIP Code		City, ST ZIP Code	

Validação do escopo de compromisso (cont.)

- Perguntas sobre orçamento e retorno do investimento (ROI) podem surgir tanto do lado do cliente quanto do lado do testador em testes de penetração.

Os clientes podem fazer tais perguntas:

Justificação de custo	Como explico o custo geral de testes de penetração ao meu chefe?
Necessidade de testes de penetração	Por que precisamos de testes de penetração se temos todos esses controles técnicos e não técnicos em vigor?
Fator de êxito	Como faço para incorporar testes de penetração como um fator de sucesso?
Necessidade de provedor externo	Posso fazer isso eu mesmo?
Retorno do investimento (ROI)	Como calculo o ROI para o engajamento de teste de penetração?

Explicando a importância da definição do escopo e das necessidades organizacionais ou do cliente

Validação do escopo de engajamento (cont.)

Ao mesmo tempo, o testador precisa responder perguntas como estas:

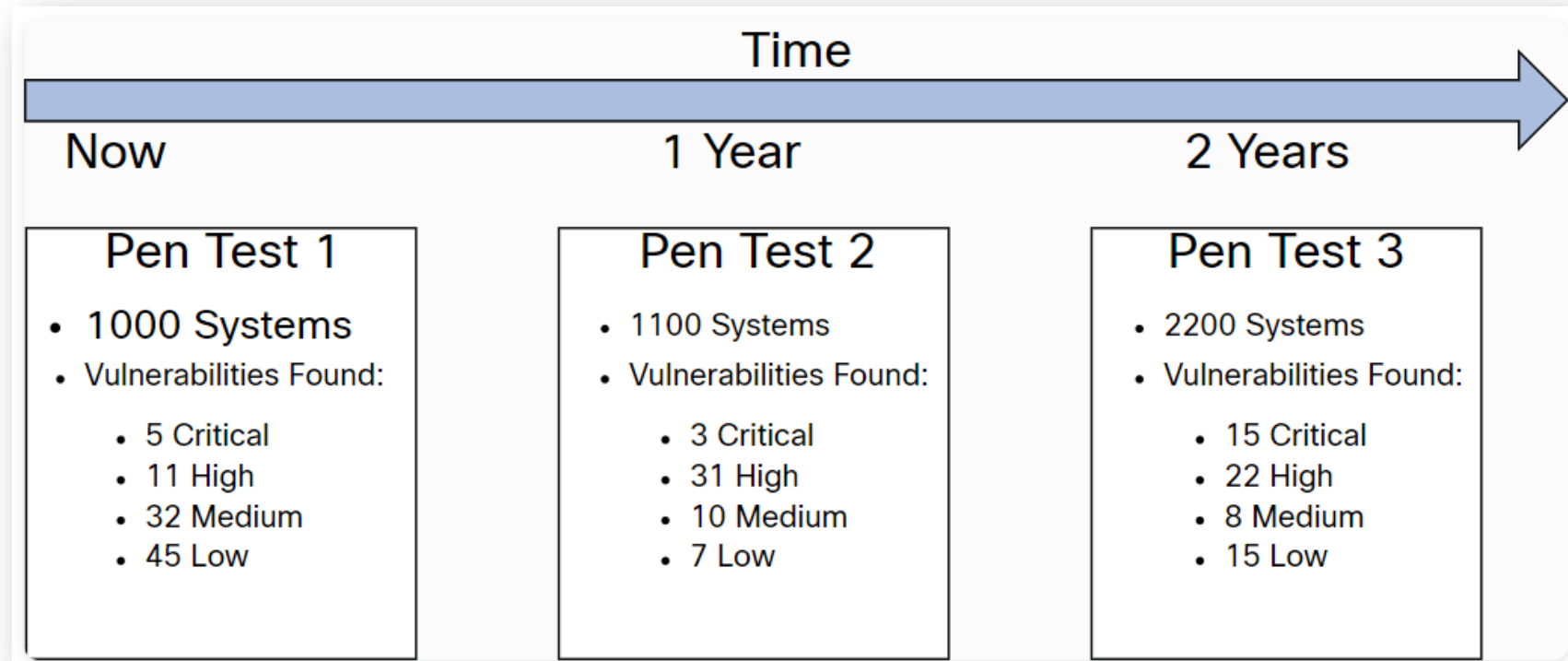
Preocupações com o orçamento	Como faço para considerar todos os itens do teste de penetração para evitar ultrapassar o orçamento?
Precificação	Como faço para definir preços?
Demonstrar ROI	Como posso mostrar claramente o ROI para meu cliente?

- As respostas a essas perguntas dependem de quão eficaz você é no escopo e na comunicação clara e na compreensão de todos os elementos do teste de penetração.
- Outro fator é entender que os testes de penetração são uma avaliação em um determinado momento.

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

Validação do escopo de engajamento (cont.)

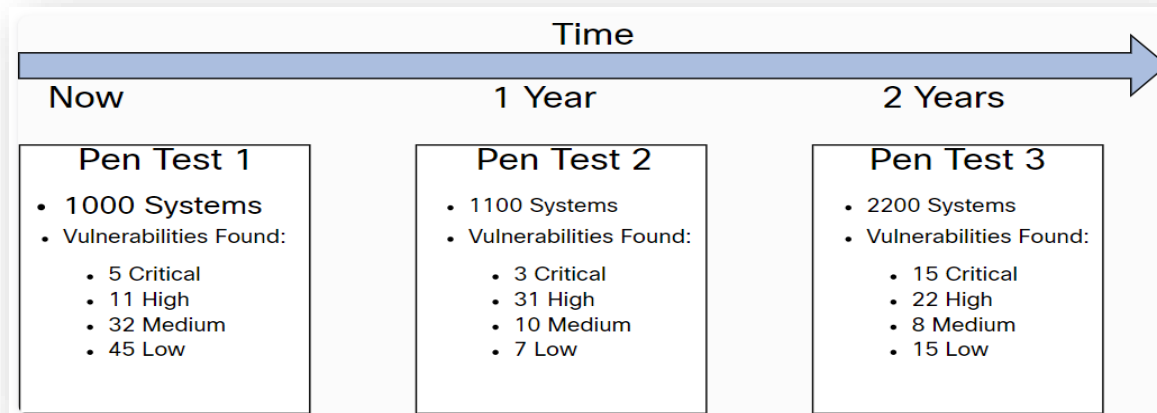
Figura 2-3 – Avaliação pontual



Isenções

- Talvez você queira adicionar isenções à documentação de pré-avaliação, bem como no relatório final.
- Por exemplo, você pode especificar que conduziu testes de penetração nos aplicativos e sistemas que existiam a partir de uma data claramente declarada. **As ameaças à segurança cibernética estão sempre mudando, e novas vulnerabilidades são descobertas diariamente. Nenhum software, hardware ou tecnologia é imune a vulnerabilidades de segurança, não importa quanto teste de segurança seja conduzido.**
- Você também deve especificar que o relatório de teste de penetração se destina apenas a fornecer documentação e que seu cliente determinará a melhor maneira de remediar quaisquer vulnerabilidades. Além disso, você deve incluir um aviso de que o seu relatório de teste de penetração não pode e não protege contra perda pessoal ou comercial como resultado do uso dos aplicativos ou sistemas descritos nele.
- Outra isenção padrão é que você (ou suas organizações) não fornece garantias, declarações ou certificações legais relativas a aplicativos ou sistemas que foram ou serão testados. Um aviso pode dizer que seu relatório de testes de penetração não representa ou garante que o aplicativo testado seja adequado para a tarefa e livre de outras vulnerabilidades ou defeitos funcionais além dos relatados. Além disso, é padrão incluir uma isenção indicando que tais sistemas não estão em total conformidade com qualquer padrão da indústria ou não são totalmente compatíveis com qualquer sistema operacional, hardware ou outro aplicativo.

Validação do escopo de engajamento (cont.)



- Na Figura 2-3, um total de três compromissos de teste de penetração ocorreram em um período de dois anos na mesma empresa.
- No primeiro compromisso, foram avaliados 1000 sistemas; 5 vulnerabilidades de gravidade crítica, 11 de alta, 32 médias e 45 de baixa gravidade foram descobertas.
- Um ano depois, 1100 sistemas foram avaliados; 3 vulnerabilidades de gravidade crítica, 31 de alta, 10 médias e 7 baixas foram descobertas.
- Dois anos depois, foram avaliados 2200 sistemas; 15 vulnerabilidades de gravidade crítica, 22 altas, 8 médias e 15 baixas foram descobertas.

Validação do escopo de compromisso (cont.)

- Você pode ver que é importante tanto para o cliente quanto para o testador de penetração compreender que os testes de penetração sozinhos não podem garantir a segurança geral da empresa.
- O testador de penetração também precisa incorporar estratégias claras e alcançáveis de mitigação para as vulnerabilidades encontradas.
- Além disso, uma análise de impacto apropriada e um prazo de correção devem ser discutidos com as respectivas partes interessadas.

Estratégia: Teste de ambiente desconhecido vs. conhecido

- Ao falar sobre estratégias de teste de penetração, é provável que você ouça os termos **testes de** ambiente desconhecido e **testes** de ambiente conhecido que são usados para descrever a perspectiva a partir da qual o teste é realizado, bem como a quantidade de informações que é fornecida ao testador.

Teste em ambiente desconhecido

(anteriormente referido como **teste de penetração de caixa preta**)

Nesse tipo de teste, ao testador é geralmente fornecida apenas uma quantidade muito limitada de informações. Por exemplo, o testador pode ser fornecido apenas os nomes de domínio e endereços IP que estão no escopo de um destino particular. A ideia desse tipo de limitação é fazer com que o testador comece com a perspectiva que um atacante externo pode ter. Normalmente, um agressor determinaria um alvo e, em seguida, começaria a reunir informações sobre o alvo, usando informações públicas, e obtendo cada vez mais informações para usar nos ataques. O testador não teria conhecimento prévio da organização e da infraestrutura do destino. Outro aspecto dos testes de ambiente desconhecido é que, às vezes, o pessoal de suporte de rede do alvo pode não receber informações sobre exatamente quando o teste está ocorrendo. Isso permite realizar um exercício de defesa, e também elimina a questão de um alvo que se prepara para o teste e não dá uma visão do mundo real da postura de segurança.

Teste de ambiente conhecido
(anteriormente conhecido como **teste de penetração em caixa -branca**)

Nesse tipo de teste, o testador começa com uma quantidade significativa de informações sobre a organização e sua infraestrutura. O testador normalmente recebe coisas como diagramas de rede, endereços IP, configurações e um conjunto de credenciais de usuário. Se o escopo incluir uma avaliação do aplicativo, o testador também poderá receber o código-fonte do aplicativo de destino. A ideia desse tipo de teste é identificar o maior número possível de furos de segurança.

Estratégia: Teste de ambiente desconhecido vs. conhecido (cont.)

- Em um teste de ambiente conhecido, o objetivo pode ser apenas identificar um caminho para dentro da organização e parar ali.
- Com testes de ambiente desconhecido, o escopo normalmente seria muito mais amplo e incluiria auditoria de configuração de rede interna e varredura de computadores de desktop para defeitos.
- Tempo e dinheiro são tipicamente fatores decisivos na determinação de qual tipo de teste de penetração completar.
- Se uma empresa possui preocupações específicas sobre um aplicativo, um servidor ou um segmento da infraestrutura, ela pode fornecer informações sobre esse destino específico para diminuir o escopo e a quantidade de tempo gasto no teste, mas ainda descobrir os resultados desejados.

Prática e Laboratório

REALIZAR:

- 2.2.8 Prática – Estratégia: Teste de ambiente desconhecido vs. conhecido;
- 2.2.9 Laboratório – Objetivo e Planejamento Pré-Engajamento;
- 2.2.10 Laboratório – Crie um Acordo de Teste de Penetração.

2.3 Demonstrando uma mentalidade ética de hacking e mantendo profissionalismo e integridade

Visão geral

Há muitos cenários em que um hacker ético (testador de penetração) deve demonstrar profissionalismo e integridade.

Verificações de antecedentes das equipes de teste de penetração	Um cliente pode exigir que você e sua equipe passem por verificações de antecedentes cuidadosas, dependendo do ambiente e do engajamento. As organizações às vezes exigem essas verificações de antecedentes para se sentirem confortáveis com as equipes de testes de penetração que estão permitindo acessar seu ambiente e informações. Seus clientes podem verificar suas credenciais e garantir que você tenha as habilidades para tornar sua rede mais segura encontrando vulnerabilidades que possam ser exploradas por agressores maliciosos.
Identificação de atividades criminosas e relato imediato de violações/atividades criminosas	Em alguns casos, você pode descobrir que um agressor real já comprometeu os sistemas e rede do cliente. Nesses casos, você deve identificar todas as atividades criminosas e relatá-las imediatamente.

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

Visão geral

2.1.2 Considerações sobre conformidade regulamentar

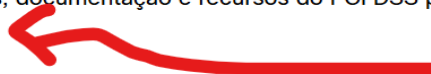


Começamos a revisar essas considerações, considerando que você foi contratado para realizar uma avaliação de conformidade. Nesse cenário, você (o testador de penetração) é contratado para verificar e auditar a postura de segurança da organização e garantir que a organização esteja em conformidade com regulamentações específicas, como a seguir. Selecione cada regulamentação para obter mais informações.

PCI DSS



A regulamentação PCI DSS (Payment Card Industry Data Security Standard, Padrão de Segurança de Dados da Indústria de Cartões de Crédito) tem como objetivo garantir o processamento de pagamentos com cartão de crédito e outros tipos de pagamentos digitais. As especificações, documentação e recursos do PCI DSS podem ser acessados no <https://www.pcisecuritystandards.org>.



HIPAA



FedRAMP



Explicando a importância do escopo e das necessidades organizacionais ou do cliente

Visão geral

<https://www.pcisecuritystandards.org/>

pcisecuritystandards.org/assessors_and_solutions/pci_forensic_investigators/

Filter by

Place of Business Language Region Servicing Country **EXPORT LIST**

Results: 20 Page: 1

Company	Place of Business	Primary Contact	Regions	Languages
3B Data Security Ltd.	Europe, UK	Keith Cottenden info@3bdatasecurity.com +44 (0)1223 298333	Europe	English
AMPCUS CYBER INC.	USA	Shanta Deep Chandra deep.chanda@ampcuscyber.com T-1 703 621 1318	USA/Canada	English, Hindi, Spanish
atsec (Beijing) Information Technology Co., Ltd	China	Yan Liu Yan@atsec.com T-86-10-5305-6681	Asia Pacific, USA/Canada	Chinese, English
BroadBand Security, Inc. (BBSec)	Japan	HongJin Choi choi@bbsec.co.jp T+81-3-5338-7430	Asia Pacific	English, Japanese, Korean

Visão geral (Cont.)

Adesão ao escopo específico de engajamento

Você já aprendeu sobre a importância de um escopo adequado do engajamento de testes de penetração. Pode haver elementos de escopo específicos da empresa que devem ser considerados. Por exemplo, você pode ter sido contratado para realizar um teste de penetração de uma empresa que está sendo adquirida pela empresa que o contratou, como parte do processo de pré-fusão. Por exemplo, a empresa adquirente pode pedir à empresa adquirida para mostrar se foram realizados testes de penetração no último ano ou nos últimos seis meses. Caso contrário, a empresa que está sendo adquirida pode ser obrigada a contratar uma empresa de teste de penetração para realizar uma avaliação. Durante a fase de escopo, o processo de seleção de destino precisa ser cuidadosamente concluído com a empresa que o contratou ou, se você fizer parte de uma equipe vermelha em tempo integral, com as partes interessadas apropriadas em sua organização. A organização pode criar uma lista de aplicativos, sistemas ou redes a serem testados. Isso é frequentemente referido como um escopo de teste de penetração "lista de permissão". Uma lista de permissão é uma lista de aplicativos, sistemas ou redes que estão dentro do escopo e devem ser testados. Por outro lado, uma lista de bloqueio é uma lista de aplicativos, sistemas ou redes que não estão no escopo e não devem ser testados. Deve sempre obedecer a essas regras.

Visão geral (Cont.)

Limitar o uso de ferramentas a um engajamento específico	Em alguns testes de penetração, você não poderá usar um conjunto particular de ferramentas que a organização não permite por razões legais ou porque essas ferramentas poderiam derrubar a rede e os sistemas subjacentes.
Limitação da invasividade com base no escopo	Após o testador de penetração e o cliente ou a parte interessada apropriada concordarem com o escopo do teste, o testador de penetração pode fazer a descoberta do alvo executando reconhecimento ativo e passivo. No Módulo 3, "Coleta de informações e Identificação de vulnerabilidade" , você aprenderá como realizar a coleta e reconhecimento de informações, como conduzir e analisar varreduras de vulnerabilidade e como aproveitar os resultados de reconhecimento de informações para se preparar para a fase de exploração de vulnerabilidades. Algumas ferramentas e ataques podem ser prejudiciais e extremamente perturbadores para os sistemas e a missão do seu cliente. Você deve sempre limitar a verbosidade e invasividade de seus testes e ferramentas com base no escopo acordado.

Visão geral (cont.)

Confidencialidade dos dados/informações	Os resultados do teste de penetração (relatório) e as informações que você pode reunir e ter acesso a durante o teste de penetração devem ser protegidas e mantidas confidenciais. Se essa informação for perdida ou compartilhada, pode ser usada por um adversário para causar muitos danos ao seu cliente.
Riscos para o profissional	Caso não aderir às melhores práticas descritas nesta lista, você pode estar sujeito a diferentes valores ou multas e, em alguns casos, até mesmo a acusações criminais. Portanto, as empresas e indivíduos que conduzem testes de penetração profissional muitas vezes têm pelo menos um seguro geral de responsabilidade empresarial. Se você está no campo de cibersegurança (muitas vezes lidando com gerenciamento de riscos), você precisa saber os riscos para a sua empresa e se proteger contra esses riscos.

Visão geral (cont.)

- Para ter um programa de cibersegurança forte, você precisa garantir que os objetivos comerciais levem em conta a tolerância ao risco e que as políticas resultantes sejam aplicadas e adotadas.
- *A tolerância ao risco é quanto de um resultado indesejável um tomador de riscos está disposto a aceitar em troca do benefício potencial.*
- **Inerentemente, o risco não é bom nem ruim. Toda atividade humana carrega algum risco, embora a quantidade varie muito.**
-
- O processo de gerenciamento de riscos exige que as organizações atribuam responsabilidades de gerenciamento de riscos, determinem o apetite de risco organizacional e a tolerância, adotem uma metodologia padrão para avaliar o risco, responder aos níveis de risco e monitorar o risco continuamente.

Visão geral (Cont.)

- O *gerenciamento* de riscos é o processo de determinar um nível aceitável de risco (apetite de risco e tolerância), calcular o nível atual de risco (avaliação de risco), aceitar o nível de risco (aceitação de risco) ou tomar medidas para reduzir o risco a um nível aceitável (mitigação de risco).
- A aceitação de risco indica que a organização está disposta a aceitar o nível de risco associado a uma determinada atividade ou processo.
- Geralmente, mas nem sempre, isso significa que o resultado da avaliação de risco está dentro da tolerância.
- Pode haver momentos em que o nível de risco não esteja dentro da tolerância, mas a organização ainda escolherá aceitar o risco porque todas as outras alternativas são inaceitáveis.
- As exceções devem sempre ser trazidas à atenção da administração e autorizadas pela administração executiva ou pelo conselho de administração.

Explicando a importância do escopo e requisitos organizacionais ou do cliente

Prática e Laboratório

REALIZAR:

- 2.3.2 Prática – Demonstre uma mentalidade de hacking ético;
- 2.3.3 Laboratório – Código de Conduta Pessoal.

2.4 Resumo de planejamento e escopo de uma avaliação de teste de penetração

O que eu aprendi neste módulo?

Comparar e contrastar conceitos de governança, risco e conformidade

- A fase de planejamento e preparação é crucial em qualquer teste de penetração e envolve escopar o projeto adequadamente.
- Isso inclui a compreensão do público-alvo, regras de engajamento, canais de comunicação, recursos disponíveis, orçamento, restrições técnicas e quaisquer isenções.
- Além disso, é essencial estar familiarizado com as diversas considerações de conformidade regulamentar, incluindo PCI DSS, HIPAA, FedRAMP e GDPR.
- A maioria dessas regulamentações exige testes de penetração de terceiros para verificar a conformidade e avaliar a postura de segurança da organização.
- É importante estar familiarizado com esses regulamentos e suas listas de verificação para uma avaliação bem-sucedida com base em conformidade.

O que eu aprendi neste módulo?(Cont.)

Regulamentações do setor financeiro

- O setor financeiro é responsável pela salvaguarda das informações dos clientes e pela manutenção da infraestrutura crítica dos serviços financeiros.

Regulamentações do setor de saúde

- A Regra de Segurança HIPAA, publicada em 2003, exige salvaguardas técnicas e não técnicas para proteger informações sobre saúde eletrônicas.

Padrão de Security de Dados da Indústria de Cartões de Crédito (PCI DSS)

- O Payment Card Industry Security Standards Council (PCI SSC) foi formado por grandes marcas de cartões de pagamento (Visa, MasterCard, Discover e American Express) para desenvolver o Payment Card Industry Data Security Standard (PCI DSS) a fim de proteger os titulares de cartão contra uso incorreto de suas informações pessoais e minimizar perdas de canal de cartão de pagamento.

O que eu aprendi neste módulo?(Cont.)

Elementos técnicos principais das regulamentações que você deve considerar

- Vários elementos técnicos importantes são exigidos pela maioria das regulamentações, incluindo isolamento de dados, gerenciamento de senhas e gerenciamento de chaves.
- O isolamento de dados envolve a criação de uma rede separada para sistemas envolvidos no processamento de cartões de pagamento para garantir que eles estejam completamente isolados.
- As estratégias de gerenciamento de senhas devem atender a padrões de implementação específicos e devem incluir o uso de senhas fortes e autenticação multifator.
- O gerenciamento de chaves também é crítico e envolve o gerenciamento e proteção adequados de chaves criptográficas para garantir a segurança das informações protegidas pela criptografia.
- As políticas e padrões para o gerenciamento das chaves devem incluir responsabilidades atribuídas, a natureza das informações a serem protegidas, as classes de ameaças e os mecanismos de proteção criptográfica a serem utilizados.

O que eu aprendi neste módulo?(Cont.)

Elementos técnicos principais das regulamentações que você deve considerar

- Vários elementos técnicos importantes são exigidos pela maioria das regulamentações, incluindo isolamento de dados, gerenciamento de senhas e gerenciamento de chaves.
- O isolamento de dados envolve a criação de uma rede separada para sistemas envolvidos no processamento de cartões de pagamento para garantir que eles estejam completamente isolados.
- As estratégias de gerenciamento de senhas devem atender a padrões de implementação específicos e devem incluir o uso de senhas fortes e autenticação multifator.
- As políticas e padrões para o gerenciamento de chaves devem incluir responsabilidades atribuídas, a natureza das informações a serem protegidas, as classes de ameaças e os mecanismos de proteção criptográfica a serem utilizados.

O que eu aprendi neste módulo?(Cont.)

Considerações Legais

- Conceitos legais importantes que são relevantes para a realização de um teste de penetração incluem SLAs (Acordos de nível de Serviço), acordos de confidencialidade, SOWs (declarações de trabalho), MSAs (acordos de serviço mestre) e NDAs (acordos de não divulgação).
- A seção também enfatiza a importância dos contratos em um teste de penetração e a necessidade de clareza, especificidade e aconselhamento jurídico.
- Por fim, sugere a adição de isenções à documentação pré-engajamento e aos relatórios finais para abordar as limitações dos testes de penetração e evitar possíveis responsabilidades legais.

O que eu aprendi neste módulo?(Cont.)

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

- O documento de regras de engajamento destaca as condições sob as quais os testes serão realizados e inclui detalhes como o cronograma de testes, o local dos testes, a janela de tempo dos testes, o método preferido de comunicação, controles de segurança que poderiam potencialmente impedir testes, endereços IP ou redes a partir dos quais os testes se originarão e tipos de testes permitidos ou não permitidos.
- O escopo é um dos elementos mais importantes das tarefas de pré-engajamento e inclui a documentação dos sistemas, redes e aplicativos a serem testados, bem como todos os requisitos específicos necessários para o teste.
- Há diferentes tipos de documentação da API e recursos de apoio adicionais que podem estar disponíveis para o testador de penetração.
- O escopo de envolvimento deve incluir localização física, nomes de domínio totalmente qualificados de DNS e identificação de destino externo versus interno.

O que eu aprendi neste módulo?(Cont.)

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

- É importante validar o escopo de um teste de penetração e entender o público-alvo do relatório.
- O tópico contém uma lista de perguntas que podem ajudar a descobrir diferentes características do público-alvo, como sua necessidade pelo relatório, sua posição na organização e sua responsabilidade e autoridade em tomar decisões com base nas descobertas.
- Também é importante manter linhas abertas de comunicação com clientes e partes interessadas.
- O tópico fornece uma lista de perguntas a serem consideradas durante a comunicação com as partes interessadas.
- Além disso, pode haver perguntas sobre orçamento e retorno do investimento que podem surgir tanto do cliente quanto do lado do testador nos testes de penetração.
- Assegure-se de que o cliente entenda que o teste de penetração é uma avaliação pontual e que estratégias claras e alcançáveis de mitigação, análise de impacto e prazos de correção devem ser discutidos com todas as partes interessadas.

O que eu aprendi neste módulo?(Cont.)

Explicando a importância do escopo e das necessidades organizacionais ou do cliente

- **O teste** de ambiente desconhecido envolve dar ao testador apenas informações limitadas, como nomes de domínio e endereços IP, para simular a perspectiva de um atacante externo.
- O testador não tem conhecimento prévio da organização e da infraestrutura do destino, e o pessoal de suporte de rede do destino pode não ser informado sobre o teste.
- Isso permite uma avaliação realista da postura de segurança.
- **O teste** de ambiente conhecido, por outro lado, fornece ao testador uma quantidade significativa de informações sobre a organização e sua infraestrutura, incluindo diagramas de rede, endereços IP, configurações e credenciais de usuário. Em alguns casos, o testador também pode receber o código-fonte do aplicativo de destino. O objetivo desse tipo de teste é identificar o maior número de furos de segurança possível.
- O escopo do teste e o tempo e dinheiro gastos nele dependem de diversos fatores, como preocupações específicas da empresa e o nível de sofisticação e capacidade de possíveis atacantes.
- Embora testes de ambiente conhecido possam ser úteis para identificar vulnerabilidades específicas, testes de ambiente desconhecido geralmente são uma boa escolha, pois fornecem uma avaliação mais realista da postura de segurança da rede.

O que eu aprendi neste módulo?(Cont.)

Demonstrando uma mentalidade de hacker ético, mantendo profissionalismo e integridade

- Este tópico aborda várias considerações importantes para hackers éticos ou testadores de penetração para demonstrar profissionalismo e integridade.
- Elas incluem passar por verificações de antecedentes, aderir ao escopo específico de engajamento, identificando atividades criminosas e reportando-as imediatamente, limitando o uso das ferramentas, respeitando a invasividade com base no escopo, mantendo a confidencialidade de dados e informações e entendendo os riscos envolvidos.
- Além disso, o tópico enfatiza a importância da gestão de riscos e da tolerância ao risco nos programas de governança de cibersegurança.
- Todas as partes envolvidas devem tomar decisões informadas e gerenciar riscos enquanto mantêm os objetivos organizacionais em mente.



Networking
Academy



Programa
CiberEducação
Cisco-Brasil



Obrigado pela Atenção